SAD · UNIDAD 3

El cortafuegos: el vigilante de la empresa

Quién entra, quién sale y quién no pasa

HOY

Dos horas, dos preguntas

1.ª hora · El cortafuegos (UD3)

¿Cómo protegemos la empresa de lo que viene de Internet?

2.ª hora · La VPN (UD4)

¿Cómo entra un empleado desde su casa sin abrir la puerta a todo el mundo?

LA IDEA DE HOY — La empresa es un edificio. El cortafuegos es el vigilante de la entrada.

LA IDEA DE HOY

La empresa es un edificio



Todo pasa por delante del vigilante. La tienda está abierta al público; las oficinas, no. Y si alguien asalta la tienda, no puede llegar a las oficinas.

RECUERDA — Internet = la calle · DMZ = la tienda · LAN = las oficinas · cortafuegos = el vigilante

EL VIGILANTE

Mira tres cosas



¿De dónde vienes?

la IP de origen

de la calle · de las oficinas



¿A dónde vas?

la IP de destino

a la tienda · a las oficinas



¿Por qué puerta?

el puerto

80 = web · 22 = SSH

Lo que NO hace: abrir la mochila. No mira lo que va dentro del paquete (eso lo hace el WAF, en la UD5).

EN UNA FRASE — El cortafuegos decide por el sobre (origen, destino, puerto), no por la carta.

LA REGLA DE ORO

Si no estás en la lista, no pasas

Lista blanca ✔

Todo prohibido, salvo lo que está en la lista.
Si se te olvida algo, no funciona: te das cuenta enseguida.

Lista negra ✘

Todo permitido, salvo lo que está en la lista.
Si se te olvida algo, queda abierto… y no te enteras.

en nftables

```
policy drop;        # lo que no esté en la lista, fuera
```

SIEMPRE — policy drop: lista blanca.

CÓMO LEE LA LISTA

De arriba abajo: la primera que encaja, manda

1	oficinas → calle	pasa
2	tienda → oficinas	fuera (drop)
3	todo el mundo → puerta 22	pasa
—	nadie más (policy)	fuera (drop)

Llega alguien de la tienda que quiere ir a las oficinas por la puerta 22...

Línea 1: no encaja.
Línea 2: SÍ → fuera.
La línea 3 ni se lee.

El orden de las líneas es parte de la seguridad.

PREGUNTA — ¿Y si la línea 3 estuviera la primera? → pasaría.

DOS TIPOS DE VISITA

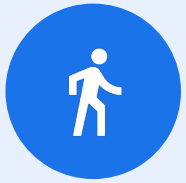
¿Vienes a ver al vigilante, o vas a otro sitio?

input



Vienes a hablar con el VIGILANTE.
Ej.: el administrador entra al cortafuegos por SSH.

forward



PASAS por delante del vigilante hacia otro sitio.
Ej.: de la calle a la tienda.

Casi todo el trabajo está en forward: quién puede ir de una zona a otra.

PREGUNTA — Un PC de la oficina pide la web de la tienda: ¿input o forward? → forward

LA MEMORIA DEL VIGILANTE

Si saliste tú, te deja volver



en nftables: la primera línea, siempre

```
ct state established,related accept      # si saliste tú, vuelves
```

SI SE OLVIDA — No funciona nada, ni navegar, y no sale ningún error.

Quién puede ir a dónde

De la calle	→ a la tienda (web: 80 y 443)	✓
De la calle	→ a las oficinas	✗
De las oficinas	→ a la calle (navegar)	✓
De las oficinas	→ a la tienda (SSH, para administrarla)	✓
De la tienda	→ a las oficinas	✗

LA MÁS IMPORTANTE — La tienda NO entra en las oficinas: si asaltan la web, el ladrón se queda en la tienda.

La centralita de la empresa

Salir: masquerade

Los empleados llaman a la calle con el NÚMERO DE LA EMPRESA (la IP pública). Fuera no se ven sus extensiones.

Entrar: DNAT

Quien llama al número de la empresa preguntando por la web, la centralita le PASA A LA TIENDA.

en nftables

```
oifname "wan" masquerade                        # salir con la IP de la empresa
iifname "wan" tcp dport { 80, 443 } dnat to 10.10.20.10     # la web, a la tienda
```

OJO — Con el DNAT no basta: el vigilante también tiene que dejarle pasar (una línea en forward).

EL VIAJE DE UN PAQUETE

Tres puestos de control, siempre en el mismo orden

1 **`prerouting`**

Nada más entrar

La centralita cambia el destino
DNAT: a la tienda

2 **`forward`**

Pasar de zona a zona

El vigilante decide si pasa
(ya ve el destino NUEVO)

3 **`postrouting`**

Justo antes de salir

Cambia el origen
masquerade: la IP de la empresa

Ejemplo: la calle pide 203.0.113.254:80 → **1** pasa a ser 10.10.20.10:80 → **2** ¿hay una línea «la calle → la tienda, 80»? Si no, fuera.

POR ESO — DNAT (paso 1) + una línea en forward (paso 2). Si falta la segunda, la web no contesta.

EL FICHERO

La lista del vigilante, traducida

```
policy drop;
```
→ Si no estás en la lista, no pasas

```
ct state established,related accept
```
→ Si saliste tú, vuelves

```
iifname $LAN oifname $WAN accept
```
→ Las oficinas, a la calle

```
iifname $WAN … tcp dport { 80, 443 } accept
```
→ La calle, a la web de la tienda

```
iifname $DMZ oifname $LAN drop
```
→ La tienda NO entra en las oficinas

```
oifname $WAN masquerade
```
→ Salir con la IP de la empresa

NO SE MEMORIZA — Se entiende. El fichero entero está en la web, apartado 5.4 de la UD3.

DE LA TABLA A LA REGLA

Cuatro preguntas, siempre las mismas

La fila: De la calle → a la tienda (web: 80 y 443)

1	**¿De dónde viene?**	de la calle	`iifname $WAN`
2	**¿A dónde va?**	a la tienda, a la web	`oifname $DMZ ip daddr $WEB`
3	**¿Por qué puerta?**	80 y 443	`tcp dport { 80, 443 }`
4	**¿Qué hago?**	dejarle pasar	`accept`

```
iifname $WAN oifname $DMZ ip daddr $WEB tcp dport { 80, 443 } accept comment "calle -> web"
```

Y AL FINAL — comment "...": para qué es la regla. Dentro de un mes no te acordarás.

DEMO · PASO 1

Sin vigilante: la tienda entra en las oficinas

terminal

```
$ ./lab.sh web                          # entro en la tienda (el servidor web)
$ curl -m 3 http://10.10.10.5           # le pido una página a un PC de la oficina
PC de la LAN (intranet) · te llega una peticion desde 10.10.20.10      ← ¡ha llegado!
```

Mal

Si alguien asalta la web, tiene camino libre hasta los ordenadores de la oficina.

Y EL COMPROBADOR — ./lab.sh comprobar ud3 → casi todo en rojo. Es el punto de partida.

DEMO · PASO 2

Ponemos al vigilante: tres pasos de siempre

1

Edita

La lista del vigilante

`firewall/nftables.conf`

2

Aplica

Comprueba y carga.
Si hay un error, no carga nada

`./lab.sh aplicar`

3

Mira

Las reglas, con un contador
de paquetes en cada una

`./lab.sh ver`

TRANQUILO — Si el fichero tiene un error, ./lab.sh aplicar no carga nada: nunca te quedas a medias.

DEMO · PASO 3

Probamos: tres pruebas, tres ideas

1 **tienda → oficinas**

`./lab.sh web → curl -m 3 http://10.10.10.5`

Se queda colgado: el vigilante lo ignora (drop)

2 **calle → número de la empresa**

`./lab.sh internet → curl http://203.0.113.254`

Contesta la tienda: la centralita le pasa (DNAT)

3 **oficinas → calle**

`./lab.sh pc → curl http://203.0.113.50`

Fuera ven «desde 203.0.113.254»: la IP de la empresa

AL FINAL — ./lab.sh comprobar ud3 → ✔️ 8 de 8

COMO UN ATACANTE

nmap: llamar a todas las puertas

```
./lab.sh internet
nmap -Pn -p 22,80,443,8080 203.0.113.254
```

open



Llamas y te abren

Hay un servicio (80: la web)

closed



Llegas a la puerta y no hay nadie

El vigilante te dejó pasar (443)

filtered



El vigilante te ignora

No sabes ni si hay puerta (22, 8080)

EL BUENO — filtered: el atacante no sabe ni si la máquina existe.

ERRORES TÍPICOS

Los cuatro que vais a cometer

No funciona nada (ni navegar)

Falta la línea de la memoria: established,related

Las oficinas no salen a la calle

Falta el masquerade

La web publicada no contesta

Hay DNAT, pero falta dejarle pasar en forward

La tienda llega a las oficinas

Una línea más general arriba: la primera que encaja, manda

SIEMPRE — ./lab.sh aplicar → ./lab.sh ver (¿sube el contador?) → ./lab.sh comprobar ud3

LO QUE NOS LLEVAMOS DE LA UD3

Resumen de puntos clave

- Calle = Internet · tienda = DMZ · oficinas = LAN
- El cortafuegos mira origen, destino y puerto
- Lista blanca: policy drop
- La primera línea que encaja, manda
- established,related: si saliste tú, vuelves
- masquerade para salir · DNAT para la web

DESPUÉS DEL DESCANSO

¿Y si Lucía trabaja desde casa?

- Las oficinas están cerradas a la calle
- Abrir la puerta = deshacer todo
- La respuesta: una VPN

El vigilante cierra la puerta; la VPN será la única llave para entrar desde casa.